Policy 14 – Secure SDLC

1. Table of Contents

1 Document Content Page

2 Policy Objectives and Scope

2.1 Purpose

2.2 Scope

2.3 Security Requirements & Stories

2.4 Code Review & Static Analysis

2.5 Dependency & Secrets Scanning

2.6 Build Pipeline Security

2.7 Pre-Release Penetration Testing

3 Policy Compliance

3.1 Compliance Measurement

3.2 Exceptions

3.3 Non-Compliance

3.4 Continual Improvement

2. Policy Objectives and Scope

2.1 Purpose – Embed security checks into every stage of software design, development, and deployment.

2.2 Scope – All custom code, Infrastructure-as-Code, scripts, and APIs maintained by the organisation.

2.3 Security Requirements & Stories

- Capture security user stories or tasks during backlog grooming.
- Reference relevant standards (e.g., input validation, auth flows).

2.4 Code Review & Static Analysis

- Require peer code review for every pull request. OR
- Run automated static-analysis tooling with blocking rules on critical findings.

2.5 Dependency & Secrets Scanning

- Scan third-party packages for known CVEs on every build.
- Reject commits containing hard-coded secrets.

2.6 Build Pipeline Security

- Isolate build runners; authenticate to artifact repo via short-lived tokens.
- Sign release artifacts; verify hash during deployment.

2.7 Pre-Release Penetration Testing

- Conduct internal or third-party pen test for major releases or annually.
- Track findings to closure before public launch.

3. Policy Compliance

3.1 Compliance Measurement – CI pipeline gates show 100 % code scanned; no critical findings open on release.

3.2 Exceptions – Temporary allow-lists require documented risk and fix timeline.

3.3 Non-Compliance – Code merged without review or scan reverted; build blocked until rectified.

3.4 Continual Improvement – Integrate new security tooling and OWASP guidance each year.